🎓 Mémo RADIUS — BTS SIO 2e année (option SISR)

> Tout ce qu'il faut savoir sur le protocole RADIUS pour les cours, les TP et l'examen E5.

1. C'est quoi RADIUS ?

RADIUS = *Remote Authentication Dial-In User Service*.

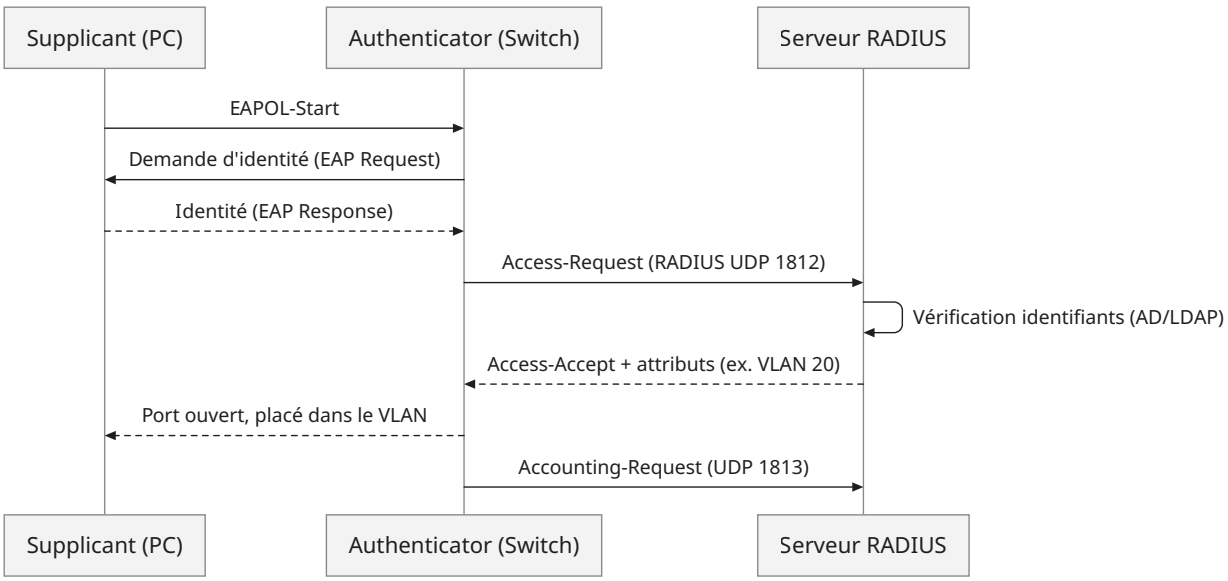
- Protocole **client-serveur** qui centralise l'**authentification**, l'**autorisation** et la **comptabilisation** des accès réseau → on parle du triptyque **AAA** (*Authentication, Authorization, Accounting*).
- Défini par les RFC 2865 (authentification) et 2866 (accounting).
- Développé à l'origine pour les accès distants (modems), aujourd'hui très utilisé pour le **Wi-Fientreprise (802.1X)** et le **VPN**.
- Fonctionne en **UDP**, ports **1812** (authentification) et **1813** (accounting). ⚠️ Historiquement 1645/1646 — à connaître car encore visibles sur certains équipements.
- Il chiffre **seulement le mot de passe** (algorithme MD5 + secret partagé) dans les paquets classiques : c'est sa faiblesse face à **TACACS+** (Cisco, TCP 49, chiffre tout, sépare les 3 A). En Wi-Fi 802.1X, la protection vient de **TLS** dans le tunnel EAP, pas de RADIUS lui-même.

2. AAA : les 3 rôles

A	Rôle	Exemple
Authentication	« Qui es-tu ? »	Vérifier identifiant + mot de passe
Authorization	« Qu'as-tu le droit de faire ? »	VLAN 20 pour les élèves, VLAN 30 pour les profs
Accounting	« Que fais-tu ? »	Journaliser connexions, durées, volumes

3. Les acteurs et le fonctionnement

- **Supplicant** : le client qui demande l'accès (PC, smartphone, imprimante).
- **Authenticator** : l'équipement d'accès qui relaie (switch 802.1X, point d'accès Wi-Fi, NAS, serveur VPN). C'est le **client RADIUS** au sens protocolaire.
- **Authentication Server** : le serveur RADIUS (FreeRADIUS, NPS Windows Server, Cisco ISE…) qui vérifie les identités dans une base (Active Directory, LDAP, fichier local…).



Les codes de réponse RADIUS à connaître :

Code	Signification
Access-Request	Le switch/NAS demande l'authentification
Access-Accept	Identité validée (+ attributs : VLAN, ACL…)
Access-Reject	Identifiants refusés
Access-Challenge	Information complémentaire demandée (ex. 2e facteur, EAP-TLS)

4. EAP, PEAP, TLS : ne pas mélanger

- **802.1X** : cadre général d'authentification des ports (Wi-Fi ou filaire). Il utilise **EAP**.
- **EAP** (*Extensible Authentication Protocol*) : le « transport » des méthodes d'authentification.
- **EAP-TLS** : la méthode la plus sûre → **certificats des deux côtés** (client + serveur). Nécessite une PKI.
- **PEAP-MSCHAPv2** : certificat **uniquement côté serveur**, mot de passe AD côté client. Le plus courant en entreprise avec Windows/AD.

💡 Astuce examen : **802.1X = comment on s'authentifie sur le port**, **RADIUS = qui tranche entre le switch/AP et le serveur d'authentification**.

5. Mise en place typique (TP type)

1. **Installer le serveur RADIUS** (FreeRADIUS sous Linux ou NPS sous Windows Server) et l'intégrer à l'annuaire (Active Directory/LDAP).
2. **Déclarer le switch/AP comme client RADIUS** avec son IP et un **secret partagé**.
3. **Déclarer le serveur RADIUS sur le switch/AP** (`radius-server host x.x.x.x key ...` chez Cisco).
4. **Activer 802.1X sur les ports** d'accès (+ éventuellement MAB — *MAC Authentication Bypass* — pour les imprimantes).
5. **Définir les politiques** : VLAN dynamiques, ACL, comptes de test.
6. **Tester** : authentification réussie, refusée, journalisation accounting.
7. **Sécuriser** : certificats valides (PKI), secret partagé robuste, redondance (2 serveurs RADIUS).

Exemple FreeRADIUS (Linux)

```
# Déclarer le client (switch/AP)
nano /etc/freeradius/3.0/clients.conf
# client switch-etage1 {
# ipaddr = 192.168.1.2
# secret = S3cretPartage
# }
# Tester en local
radtest eleve1 MotDePasse 127.0.0.1 0 testing123
```

Exemple NPS (Windows Server)

- Rôle « Services de stratégie et d'accès réseau » → **NPS**.
- Créer un **client RADIUS** (le switch/AP) + une **stratégie réseau** (conditions : groupe AD, type EAP ; paramètres : VLAN attribué).

6. Vocabulaire express

Terme	Définition courte
NAS	*Network Access Server* : l'équipement qui relaie (synonyme d'authenticator)
Secret partagé	Mot de passe commun entre authenticator et serveur RADIUS
MAB	Authentification par adresse MAC (appareils non 802.1X)
PKI	Infrastructure de clés/certificats (nécessaire à EAP-TLS)
VLAN dynamique	VLAN attribué par le serveur RADIUS après authentification

7. Pièges classiques d'examen 🚨

- Confondre **client RADIUS** (= le switch/AP) et **supplicant** (= le PC).
- Oublier d'ouvrir les ports **UDP 1812/1813** sur le pare-feu.
- Secret partagé différent côté switch et côté serveur → *Access-Reject* silencieux.
- Certificat serveur expiré ou non approuvé par le client → échec PEAP/EAP-TLS.
- Dire que « RADIUS chiffre tout » : faux, seul le mot de passe est protégé hors tunnel EAP.
- Oublier que **RADIUS ne remplace pas un pare-feu ni une PKI** : c'est un composant AAA.

8. RADIUS vs TACACS+ en 10 secondes

Critère	RADIUS	TACACS+
Transport	UDP 1812/1813	TCP 49
Chiffrement	Mot de passe seul	Paquet entier
AAA	Fusionne authentification/autorisation	Les 3 A séparés
Usage	Accès réseau utilisateurs (Wi-Fi, VPN)	Administration des équipements Cisco

---

✅ **À retenir absolument** : AAA, les 3 acteurs (supplicant / authenticator / serveur), UDP 1812-1813, Access-Request / Accept / Reject / Challenge, 802.1X + EAP, et le rôle du secret partagé.